HALLAZGO TCK-25B8E4 Nuevo

Software Seguro v1.0.0

Plantilla: Auditoría de Seguridad

Ref ID: TCK-25B8E4

TÍTULO DE LA VULNERABILIDAD

IDOR en la API de turnos: acceso y eli minación de turnos de otros usuarios

NIVEL DE CRITICIDAD

Alta

RESUMEN EJECUTIVO

El riesgo en lenguaje de negocio: leer agendas ajenas + cancelar turnos de víctimas

ENDPOINT O URL AFECTADA

`GET /api/1/appointments/{id}` — consu lta de turnos por ID
`DELETE /api/appointments/{id}` — canc elación (borrado) de turno por ID

CASO DE USO ASOCIADO

Gestión de turnos: consulta de turnos propios
Gestión de turnos: cancelación de turn os propios

VERIFICACIÓN OWASP ASVS V4.0.3

- ✓ **V4.2.1** - Verifique que los datos confiden ciales y las API están protegidos contra at aques de referencia insegura directa de o bjetos (IDOR)... como la visualización de lo s registros de todos o la eliminación de to dos los registros.
- ✓ **V4.1.1** - Verifique que la aplicación aplica las reglas de control de acceso en una cap a de servicio de confianza, especialmente si el control de acceso del lado cliente est á presente y podría ser bypaseado.
- ✓ **V1.4.1** - Verifique que los puntos de cum plimiento de confianza, tales como puerta s de enlace de control de acceso, servidor es y funciones serverless, exijan controles de acceso. Nunca aplique controles de ac ceso en el cliente.

PUNTUACIÓN CVSS V3.1

6.3 (CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/ C:L/I:L/A:L)

DESCRIPCIÓN DETALLADA DEL HALLAZGO

Durante la evaluación de la funcionalidad de gestión de turnos se observó que:

1. El endpoint `GET /api/1/appointments/` devuelve los turnos del usuario autentica do, y cada turno se identifica por un **ID numérico secuencial** (0, 1, 2, …).

2. El botón "Cancelar" de la interfaz dispara `DELETE /api/appointments/{id}` con el ID del turno, **sin ningún token de confirmación ni verificación adicional**.
3. Al modificar manualmente el ID en la petición `GET`, el servidor **responde con los turnos de otros usuarios** sin validar que el recurso pertenezca al solicitante (IDOR — *Insecure Direct Object Reference*).
4. Los IDs son predecibles y el rango válido es amplio: la enumeración manual llegó hasta el ID 30 sin encontrar el objetivo; mediante automatización (Burp Suite Intruder) se recorrió el rango 0-150 y se localizó el recurso del usuario objetivo en el **ID 101**.
5. Con el ID de usuario, la consulta `GET /api/1/appointments/101` expone **todos los turnos del usuario objetivo con sus respectivos IDs de turno**.
6. Ejecutando `DELETE /api/appointments/{id_turno}` para cada uno de esos IDs, se eliminaron **todos los turnos del usuario objetivo** con éxito.

Causa raíz: el servidor confía ciegamente en el identificador proporcionado por el cliente y omite la verificación de autorización a nivel de objeto (¿el usuario autenticado es dueño de este turno?).

PRUEBA DE CONCEPTO (POC) Y PASOS DE REPRODUCCIÓN

Precondición: cuenta de usuario legítima en la aplicación (credenciales de prueba del laboratorio).

1. Iniciar sesión y abrir las herramientas de desarrollador (pestaña Network, filtro XHR).
2. Observar la petición `GET /api/1/appointments/` y anotar la estructura de los turnos (atributos e IDs).
3. Hacer clic en "Cancelar" sobre un turno propio y observar que se emite `DELETE /api/appointments/{id}`.
4. Repetir la petición `GET` modificando el parámetro de ID (enumeración). Verificar que el servidor devuelve turnos de otros usuarios.
5. Con Burp Suite (Intruder), recorrer los IDs 0-150 del endpoint `GET` y localizar el recurso del usuario objetivo (`xdalvik`, **ID 101**).
6. Consultar `GET /api/1/appointments/101` y extraer los IDs de todos los turnos del usuario objetivo.
7. Ejecutar `DELETE /api/appointments/{id_turno}` para cada turno obtenido.
8. **Resultado:** todos los turnos del usuario `xdalvik` son eliminados y el laboratorio confirma la explotación.

*Nota: la enumeración manual (hasta ID

RECOMENDACIÓN DE REMEDIACIÓN & MITIGACIÓN

1. **Control de acceso a nivel de objeto (prioridad crítica):** en cada petición `GET` y `DELETE`, validar en el servidor que el turno solicitado pertenezca al usuario autenticado (o que este tenga rol autorizado). Rechazar con `403/404` en caso contrario.
2. **Identificadores no secuenciales (UUID):** reemplazar los IDs numéricos secuenciales por UUIDv4, eliminando la enumerabilidad del espacio de recursos. *Esto es una mitigación complementaria, nunca un reemplazo del control de acceso.*
3. **Confirmación y autorización en operaciones destructivas:** el `DELETE` debe requerir validación de propiedad + confirmación explícita; considerar soft-delete para permitir recuperación.
4. **Rate limiting y detección de enumeración:** limitar y alertar sobre patrones de acceso secuencial a IDs (característico de ataques automatizados).
5. **No filtrar información en errores:** las respuestas a IDs inexistentes vs. no autorizados deben ser indistinguibles para evitar oráculos de enumeración.
6. **Pruebas de regresión:** incorporar casos de test de autorización a nivel de objeto (usuario A no puede leer/eliminar recursos de usuario B) en el p

```
30) resultó insuficiente; la automatiz
ación del rango 0-150 fue necesaria pa
ra localizar el objetivo, lo que evide
ncia además que los IDs secuenciales f
acilitan el ataque masivo.*
```

```
ipeline de CI/CD.
```